Midas mWIN Deployment Audit

Côme du Crest

2026-06-25

Table of contents

- Table of contents
- Midas mWIN Deployment Audit
  - Scope
  - Status
  - Conclusion
  - Legal Information And Disclaimer
  - Analysis

Midas mWIN Deployment Audit

This document presents the findings of a smart contract audit conducted by Côme du Crest.

For any inquiry contact me by email at come.ducrest@gmail.com or via telegram @ComeduCrest.

Scope

The scope of this audit is to ensure the proper deployment of the mWIN token and related contracts.

The explored contracts can be found in the following table:

Name	Address
mWIN	0x4E72025984424E52838cf8953E2863eFf036B67A
MWinCustomAggregatorFeed	0x1725A66D810C0775f6B3B0FD85646D371dA19517
MWinDataFeed	0xa27c1658730e4FAFb7fB8B257a64BbB6A0ea4077
MWinDepositVault	0xF7F1b944FCDe7805F6Ef3088817145d2eB667db4
MWinRedemptionVaultWithSwapper	0x605704d7b36d1677a8d242ded68eD505523c7924
ProxyAdmin	0xbf25b58cB8DfaD688F7BcB2b87D71C23A6600AaC
MidasTimelockController	0xE3EEe3e0D2398799C884a47FC40C029C8e241852
MidasAccessControl	0x0312A9D1Ff2372DDEdCBB21e4B6389aFc919aC4B

The scripts used for deployment were also browsed to understand the goal of deployment as of commit 0xb555954.

Status

The report has been sent to the protocol team.

Conclusion

No issues have been found with the deployment procedure and the resulting deployed contracts. All mWIN related contracts use upgradeable proxies that can can be upgraded after a 48 hours timelock. The admin rights are assumed to be controlled by Midas owned EOA.

mWIN is permissioned on transfers and uses a greenlist.

mWIN token implementation is exactly that of the `mGLOBAL token added to Aave (0x7433806912Eae67919e66aea853d46Fa0aef98A8)` apart from the different roles names (e.g. `M_WIN_MINT_OPERATOR_ROLE` instead of `M_GLOBAL_MINT_OPERATOR_ROLE`) and different mToken name and symbol as expected.

Legal Information And Disclaimer

1. This report is based solely on the information provided by Midas (the “Company”), with the assumption that the information provided is authentic, accurate, complete, and not misleading as of the date of this report. The auditor has not conducted any independent enquiries, investigations or due diligence in respect of the Company, its business or its operations.
2. Changes to the information contained in the documents, repositories and any other materials referenced in this report might affect or change the analysis and conclusions presented. The auditor is not responsible for monitoring, nor will we be aware of, any future additions, modifications, or deletions to the audited code. As such, the auditor does not assume any responsibility to update any information, content or data contained in this report following the date of its publication.
3. This report does not address, nor should it be interpreted as addressing, any regulatory, tax or legal matters, including but not limited to: tax treatment, tax consequences, levies, duties, data privacy, data protection laws, issues relating to the licensing of information technology, intellectual property, money laundering and countering the financing of terrorism, or any other legal restrictions or prohibitions. The auditor disclaims any liability for omissions or errors in the findings or conclusions presented in this report.
4. The views expressed in this report are solely my views regarding the specific issues discussed within this report. This report is not intended to be exhaustive, nor should it be construed as an assurance, guarantee or warranty that the code is free from bugs, vulnerabilities, defects or deficiencies. Different use cases may carry different risks, and integration with third-party applications may introduce additional risks.
5. This report is provided for informational purposes only and should not be used as the basis for making investment or financial decisions. This report does not constitute investment research and should not be viewed as an invitation, recommendation, solicitation or offer to subscribe for or purchase any securities, investments, products or services. The auditor is not a financial advisor, and this report does not constitute financial or investment advice.
6. The statements in this report should be considered as a whole, and no individual statement should be extracted or referenced independently.
7. To the fullest extent permitted by applicable laws, the auditor disclaims any and all other liability, whether in contract, tort, or otherwise, that may arise from this report or the use thereof.

Analysis

For all the newly deployed contracts, I report the following:

- contract was deployed by Midas RWA Deployer `0xf377e2aa453be3accd5e0350243965c98bb7149a`
- contracts are upgradeable proxies pointing to the expected implementation
- the admin and implementation are set in the same transaction as the deployment of the contract avoiding potential Clandestine Proxy In Middle of Proxy (CPIMP) attacks
- the proxy admin is `0xbf25b58cB8DfaD688F7BcB2b87D71C23A6600AaC`
- the address of `MidasAccessControl` is `0x0312A9D1Ff2372DDEdCBB21e4B6389aFc919aC4B`
- the implementation pointed by the proxy cannot be hi-jacked and cause problem to the proxy pointing to it

For the mWIN token:

- implementation is `0x8c6819c940a0122af8091d05cbeb92531d197952`
- proxy has a previous implementation `0xea1fd12592394b889f928db3ab210372d3c676df`
- it is a permissioned token that uses a `_beforeTokenTransfer()` functions to ensure the sender and recipient of transfers are greenlisted:

```
    function _beforeTokenTransfer(
        address from,
        address to,
        uint256 amount
    ) internal virtual override(mToken) {
        if (to != address(0)) {
            if (from != address(0)) {
                _onlyGreenlisted(from);
            }
            _onlyGreenlisted(to);
        }

        mToken._beforeTokenTransfer(from, to, amount);
    }
```

For MWinCustomAggregatorFeed:

- implementation is `0x0f1593dffe91f154bc703dfcbab971dcbf42be00`

For MWinDataFeed:

- implementation is `0x1d0cb5685791f6e9abc1b876e3b9017f8aa1807c`

For MWinDepositVault:

- implementation is `0x30ea22780397d82116b905e7471cca458aaf6053`
- proxy has a previous implementation `0xD7C638474B3800413E1666312da617192736B470`
- received payment tokens are sent to `0x1ED5C5AbfF8d97dBAf9D9C61C3ee744c1b9C51ac` which is the expected address provided by Midas
- fee recipient is `0x0E06F979460f39b8abC5512c14EaF70FCF662C71`
- Payment tokens: `0xA0b86991c6218b36c1d19D4a2e9Eb0cE3606eB48` (USDC), `0x6c3ea9036406852006290770BEdFcAbA0e23A0e8` (PayPal USD)
- Functions paused: `depositRequest(address,uint256,bytes32)`, `depositRequest(address,uint256,bytes32,address)`

For MWinRedemptionVaultWithSwapper:

- implementation is `0xeb21db42a06dc73353c6fa2956f5d8dadcc0879c`
- proxy has a previous implementation `0xa7D02e182264BE9940469CEd57b991DCfff12E86`
- Payment tokens are the same as for deposit vault: `0xA0b86991c6218b36c1d19D4a2e9Eb0cE3606eB48` (USDC), `0x6c3ea9036406852006290770BEdFcAbA0e23A0e8` (PayPal USD)
- Function paused: `redeemFiatRequest(uint256)`

For ProxyAdmin:

- it is the admin of all above contracts
- Simple owned contract owned by MidasTimelockController at address `0xE3EEe3e0D2398799C884a47FC40C029C8e241852`

For MidasTimelockController:

- it enforces a timelock on all operations
- owns the aforementioned ProxyAdmin
- the delay can be updated (after the delay itself)
- timelock queried at block 25387304 is 48 hours

Roles on MidasAccessControl that are new to the mWIN token and addresses with the role can be found in the following table. Assumption is that operating addresses are controlled by Midas. The mWIN token additionally use roles shared with other tokens (i.e. blacklist, greenlist, default admin) that are assumed to be controlled by Midas.

The table was computed by analysing `RoleGranted` and `RoleRevoked` events in between block 25.000.000 and 25.387.000.

Role	Hex value	Address
M_WIN_BURN_OPERATOR_ROLE	0xf7ab34f0378353f7692b914b534ef99880252f87993c6a5d232ff0107e7d20bd	0x20d4ced0efac28517c1b0a06f98b1180f28f5125
M_WIN_BURN_OPERATOR_ROLE	0xf7ab34f0378353f7692b914b534ef99880252f87993c6a5d232ff0107e7d20bd	0x605704d7b36d1677a8d242ded68ed505523c7924
M_WIN_CUSTOM_AGGREGATOR_FEED_ADMIN_ROLE	0x6989ff27a71951af85f5a9d9a72606358a057abc9e1305b5986b338da72927b4	0x532fedcf5837f411646c230cf9b743dfdd0692d3
M_WIN_DEPOSIT_VAULT_ADMIN_ROLE	0x5e436b58093eec5c9bb0bf88a6e66765dc4e9b5fd9716a7da608c87d5f7b02bf	0x2acb4bdcbef02f81bf713b696ac26390d7f79a12
M_WIN_GREENLISTED_ROLE	0xc7021654dd5cc2dc098b5f088ed0c6a046d28f5eaf2f8d0008903e2b8520acb2	0x0b776f61bbab470e10f6c890b7dbc420a3d73de0
M_WIN_GREENLISTED_ROLE	0xc7021654dd5cc2dc098b5f088ed0c6a046d28f5eaf2f8d0008903e2b8520acb2	0x19c1eb6dd1ed16706a35f36b2cc80ece744a721d
M_WIN_GREENLISTED_ROLE	0xc7021654dd5cc2dc098b5f088ed0c6a046d28f5eaf2f8d0008903e2b8520acb2	0x70b5698a75e11eba12d89b228104305c84618998

Role	Hex value	Address
M_WIN_GREENLISTED_ROLE	0xc7021654dd5cc2dc098b5f088ed0c6a046d28f5eaf2f8d0008903e2b8520acb2	0x7f390c3b0c8e183c7abc11d96e54816429f68143
M_WIN_MINT_OPERATOR_ROLE	0x226b7f9e4c18e87b8002c236d6d8eba8e3a76f5b10033d1d84bf4a084bd8b422	0x20d4ced0efac28517c1b0a06f98b1180f28f5125
M_WIN_MINT_OPERATOR_ROLE	0x226b7f9e4c18e87b8002c236d6d8eba8e3a76f5b10033d1d84bf4a084bd8b422	0xf7f1b944fcde7805f6ef3088817145d2eb667db4
M_WIN_PAUSE_OPERATOR_ROLE	0x774057df10a9815793e43daf25e762aed0ad761f84e0f8ecbf30a7c35459f2ea	0x20d4ced0efac28517c1b0a06f98b1180f28f5125
M_WIN_REDEMPTION_VAULT_ADMIN_ROLE	0xf1f308589835b1481efea09554e2f72656725481c02aa4aaadab93e7045e5a53	0x2acb4bdcbef02f81bf713b696ac26390d7f79a12